

PreCare — Risk Analysis

Security/Privacy + Product/Operations + Patient Safety

Document	Risk Analysis
Project	PreCare (iOS app + FastAPI backend)
Version / Date	v1.0 / 2026-05-14
Scope	Security & Privacy; Product/Operations; Patient Safety

1. Executive Summary

PreCare is a prenatal-support application that ingests pregnancy-related medical reports, performs OCR/text extraction, runs an AI-assisted triage to classify risk (GOOD/WARNING/DANGER), and returns recommendations to the patient. This document identifies the main risks across security & privacy, product/operations, and patient safety, and proposes mitigations.

Key takeaways: (1) the system processes highly sensitive health data (PHI/medical records) and must prioritize strong access control, data minimization, encryption at rest, and careful logging; (2) AI triage can fail in ways that impact patient safety, so conservative defaults, guardrails, and monitoring are required; (3) operational reliability depends on external model providers and robust fallbacks.

- Highest security/privacy risks: PHI stored in plaintext (uploads + SQLite), IDOR/scope bypass on report endpoints, and log leakage.
- Highest patient safety risks: false negatives (danger missed), false positives (unnecessary emergency triggers), and OCR quality failures.
- Highest operational risks: dependence on third-party LLMs, lack of production-grade DB/storage controls, and endpoint ambiguity (duplicate routes).

2. System Overview

Primary components observed in this repository:

- iOS SwiftUI client (uploads report, views results, optional acknowledgement).
- FastAPI backend (report upload + retrieval, authentication/roles, emergency trigger workflow, dashboards).
- OCR/text extraction service used on PDFs/images.
- AI triage service calling external LLM providers with fallback heuristics.

Primary data flows: the client uploads a report file to **/reports/upload**; backend stores the file under **precare__backend/uploads/**, extracts text, validates that the report appears pregnancy-related, runs risk analysis, stores results in SQLite, and returns a structured response.

3. Data Classification & Threat Model

Data types handled:

- Uploaded medical report files (PDF/images/text).
- Extracted text and derived structured values (e.g., BP, hemoglobin, proteinuria).
- User identifiers and basic profile information.
- AI-generated reasoning and recommendations (may contain sensitive content).

Primary assets to protect:

- Confidentiality and integrity of patient reports and derived triage outcomes.
- Availability of report ingestion/triage for time-sensitive cases.
- Auditability of actions (especially emergency triggers).

Threat actors considered:

- External attacker seeking unauthorized PHI access (credential stuffing, token theft, IDOR).
- Malicious or compromised client device/user attempting to access other users' data.
- Insider misuse (over-broad roles, weak audit trails).
- Third-party processor risk (LLM/OCR services, storage, crash reporting).

4. Security & Privacy Risk Analysis

4.1 Authentication & Authorization

The backend uses Bearer token authentication and role-based access checks. The primary security requirement is to ensure that every PHI endpoint enforces correct user scoping, and that tokens are validated robustly (signature, expiry, issuer/audience as applicable).

- Add automated tests for cross-user access on `/reports/{report_id}` and `/reports/user/{user_id}`.
- Prefer opaque/public IDs externally and avoid accepting raw integer IDs from clients.

4.2 Data Storage, Retention, and Encryption

Medical reports and extracted text are highly sensitive. In the current setup, uploaded files are stored under `uploads/` and reports are stored in SQLite. For production, encryption at rest and controlled retention are mandatory.

- Encrypt report files and database at rest (platform disk encryption + app-layer envelope encryption for PHI fields).
- Define a retention policy (e.g., delete raw uploads after N days; retain only derived metrics when feasible).
- Provide user-initiated deletion (including backups where legally required/possible).

4.3 Logging, Monitoring, and Incident Response

Operational logs often become an accidental exfiltration channel for PHI. The system should log only metadata needed for debugging, not full report text.

- Redact or avoid logging extracted report text, prompt payloads, and AI outputs.
- Keep an audit trail for emergency triggers and clinician/role accesses; alert on unusual access patterns.
- Document an incident response runbook (token compromise, data exposure, provider outage).

4.4 File Upload Attack Surface

Accepting PDF/image uploads introduces malware and DoS risk. Even if the backend only extracts text, parsers can be exploited and large files can exhaust resources.

- Enforce strict upload size limits and timeouts.
- Validate MIME type by content sniffing; consider scanning with an antivirus service.
- Isolate OCR and PDF parsing in a sandboxed worker process/container.

5. AI, Clinical Safety, and Patient Safety Risks

The AI triage influences patient actions (seek care vs. emergency). Safety-critical design requires conservative behavior, clear communication of uncertainty, and guardrails around automation.

5.1 Model Failure Modes

- Hallucinated values or fabricated reasoning.
- Overconfidence (high score without sufficient evidence).
- Prompt injection (report text instructing the model to output 'FINE').
- Distribution shift (unseen report formats/languages) causing OCR/triage degradation.

5.2 Safety Controls

1. Validate critical signals (BP, proteinuria, severe symptoms) using deterministic extraction where possible; do not rely solely on free-form model text.
2. Implement a 'can't tell' outcome when OCR quality is low or signals conflict; route user to manual clinician review or repeat capture.
3. Use conservative thresholds: treat missing data as higher risk; prefer WARNING over GOOD when uncertain.
4. For emergency triggers below a high-confidence threshold, require an explicit confirmation step and provide clear instructions.
5. Maintain a monitoring program: review samples, measure false positives/negatives, and tune prompts/thresholds with clinician input.

5.3 Communication Risk (UI/UX)

How results are presented can amplify harm. The app should avoid diagnostic language, clearly frame outputs as guidance, and provide next-step actions.

- Use language like 'This may indicate' and 'Consider contacting your clinician', not definitive diagnosis statements.
- Provide emergency contact instructions and local emergency number guidance; avoid implying ambulance dispatch if not guaranteed.

6. Product & Operations Risks

Operational risks impact safety when time-sensitive report triage is delayed or unavailable. Reliability engineering and safe fallbacks are required.

6.1 External Dependencies

- LLM provider outages, rate limits, latency spikes, or policy blocks.
- OCR library/parser failures or performance regressions.
- Mobile-backend connectivity failures (offline, captive portals, poor networks).

Mitigations:

- Implement strict timeouts + retries with jitter; circuit-break on repeated failures.
- Use fallback heuristic analysis when LLM calls fail; mark results as 'fallback' and encourage clinician review.
- Consider asynchronous processing: accept upload, return 'processing', notify when ready.

6.2 Data Integrity & Auditability

- Ensure report versions are tracked (original file hash, analysis model version, prompt version, timestamp).
- Keep immutable logs for emergency triggers and staff access to PHI.

6.3 Known Code/Design Risks Observed

- Two handlers appear defined for the same route `GET /reports/{report_id}`, which can lead to unpredictable behavior depending on registration order.
- Confidence/risk mapping differs between stored `risk_level` and response mapping; ensure consistent terminology (GOOD/WARNING/DANGER) across UI and storage.

7. Recommendations & Next Steps

Prioritized implementation plan (first 30–60 days):

1. Fix route ambiguity for report retrieval; add API contract tests for report flows.
2. Add encryption at rest for uploads and sensitive DB fields; define retention + deletion workflow.
3. Implement upload hardening: size limits, MIME sniffing, scanning, and sandbox OCR.

4. Add AI safety gates: ‘can’t tell’ state, conservative defaults, and monitoring with clinician review.
5. Implement logging redaction, security alerts, and an incident response playbook.

Risk Register (Summary)

Scales: Likelihood (L/M/H), Impact (L/M/H). Residual = expected risk after stated mitigations.

ID	Category	Risk	L	I	Key Mitigations (Planned / Existing)	Residual
R1	Security	Unauthorized access to PHI via weak authentication	M	M	Hardening token validation; short-lived access tokens	M
R2	Security	IDOR / scope bypass (user_id/report_id) exposing other patients' reports	M	M	Keycloak role-based tests for cross-user access	M
R3	Privacy	Sensitive report content stored unencrypted on disk (cytobates and test results)	M	M	System perms; encrypted backups	M
R4	Privacy	PHI leakage through logs / exception traces / analytics	M	M	Redact logs; disable request-body logging; LSI	M
R5	AI Safety	LLM hallucination or incorrect triage classification	M	M	Guardrails, conservative defaults; human-in-the-loop; validate ext	M
R6	Patient Safety	False negative (danger classified as low) / warning threshold tuning, escalation	M	M	on poor OCR; safety net prompts; cl	M
R7	Patient Safety	False positive emergency trigger causes panic or confusion	M	M	Low high threshold; rate-limit; audit trail	M
R8	Security	Duplicate route definitions for GET /reports /reports (reduces duplicate endpoint behavior)	M	M	LCI smoke test	M
R9	Operations	Dependence on external LLMs affects availability	M	M	Timeouts, circuit breakers; fallbacks; queued processing	M
R10	Compliance	Regulatory uncertainty for AI triage & PHI handling	M	M	Data inventory; DPIA; retention policies; consent flows; document	M
R11	Security	Prompt injection via uploaded text influences model output	M	M	Untrusted; strict JSON; more instructions; filter	M
R12	Operations	SQLite risks: corruption, concurrency limits	M	M	Backups, production DB; encrypted backups; migrations	M
R13	Product	Misleading UI copy implies diagnosis or guarantee	M	M	Clear language; disclaimers; review content	M
R14	Security	File upload risks (malicious PDFs/images, large file size, DoS)	M	M	Scanning; rate limiting; isolate parsing	M
R15	Privacy	Retention of raw reports longer than needed	M	M	Retention schedule; user deletion; minimize stored text	M

Appendix A — Assumptions and Limitations

- This assessment is based on repository code review and intended flow described in README.md as of 2026-05-14.
- Deployment architecture (cloud provider, network segmentation, WAF, secrets management) is not fully specified; production controls may differ.
- Clinical validation is not performed here; safety recommendations assume this is a decision-support tool, not a diagnostic device.